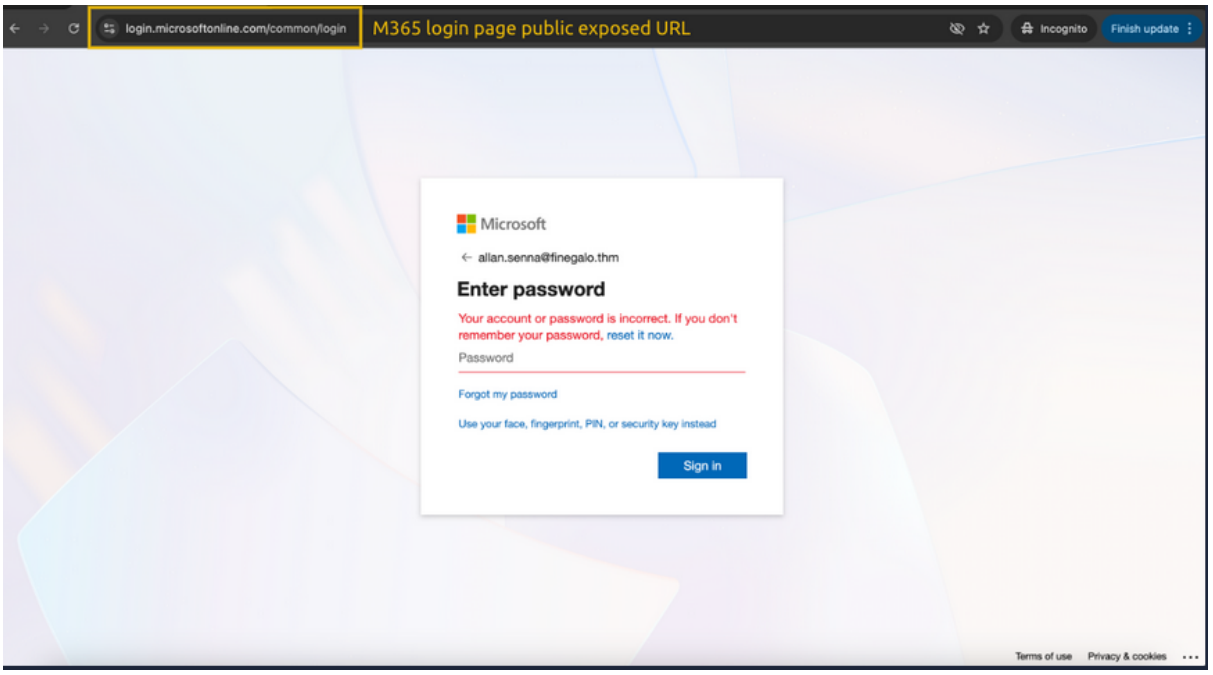
Análise de logs do Entra ID no Splunk

Sites de vazamento de credenciais e bancos de dados de violações de segurança fornecem aos atacantes listas prontas de nomes de usuário e senhas reais. Muitas dessas credenciais estão vinculadas a contas corporativas ativas, onde os usuários reutilizaram senhas de serviços pessoais.

A Entra ID é um alvo especialmente atraente porque seus endpoints de autenticação são expostos à internet por design. Qualquer atacante com uma lista de nomes de usuário pode começar a tentar logins sem nunca tocar no perímetro da rede do alvo. E quando um login é bem-sucedido, ele pode parecer idêntico a um legítimo, sem exploits, malware ou anomalias na rede. A única maneira de detectá-lo é por meio da análise de logs.



Ataque de Pulverização de senhas (Password Spraying)

O atacante tenta um pequeno conjunto de senhas comuns em várias contas. O objetivo é permanecer abaixo dos limites de bloqueio.

Os limites de bloqueio são políticas de proteção que bloqueiam contas após atingirem um número predefinido de tentativas falhas. Quando um usuário é bloqueado, ele não pode acessar sua conta até que um administrador ou um tempo limite definido a desbloqueie.

Por exemplo, se a política estiver configurada para bloquear a conta após 10 tentativas falhas, o atacante nunca ultrapassa 5 tentativas por conta para permanecer discreto. O volume de tentativas é distribuído entre várias contas, em vez de concentrado em uma única conta.

Como isso aparece nos logs:

Várias tentativas de login falhas a partir do mesmo endereço IP.

Falhas distribuídas entre vários nomes de usuário diferentes.

Todas as tentativas ocorrem em um curto período de tempo.

Ataques de Força Bruta

Por outro lado, em ataques de força bruta, o atacante tenta várias senhas em uma única conta. Essa técnica é menos comum contra o Entra ID devido às políticas de bloqueio. No entanto, os atacantes podem contornar isso limitando suas tentativas e distribuindo-as ao longo de um período extenso, de forma que nunca ultrapassem o limite de bloqueio.

Por exemplo, um atacante pode tentar apenas uma senha por hora na mesma conta. Isso mantém o ruído baixo o suficiente para evitar o acionamento de um bloqueio, tornando o ataque lento e mais difícil de detectar, pois as tentativas podem ocorrer em um intervalo de tempo maior.

Como isso se manifesta nos logs:

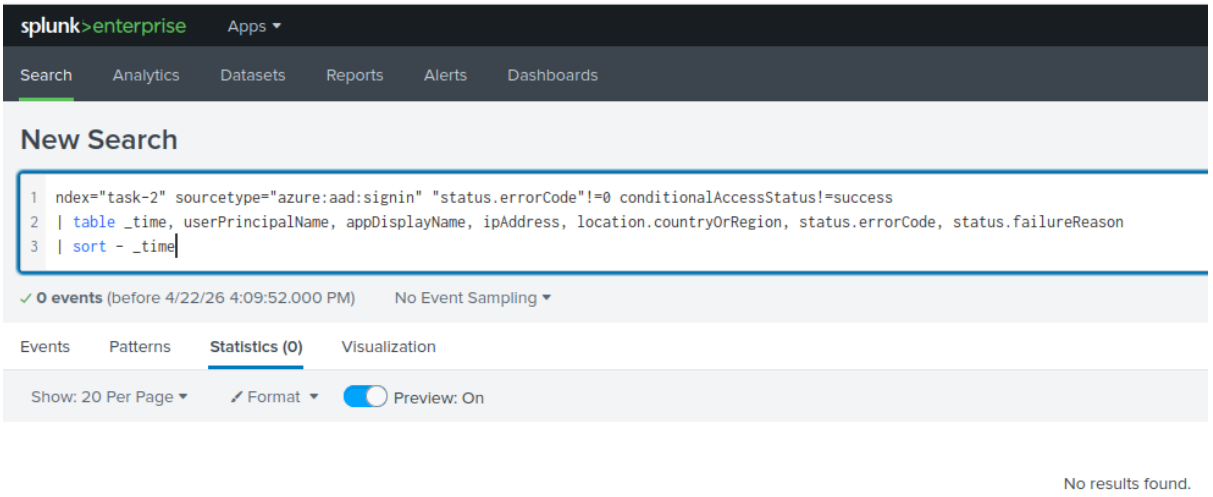
Muitas tentativas de login malsucedidas para um único nome de usuário.

Alto volume de tentativas de um único IP ou de um pequeno número de IPs.

Detecção com Logs

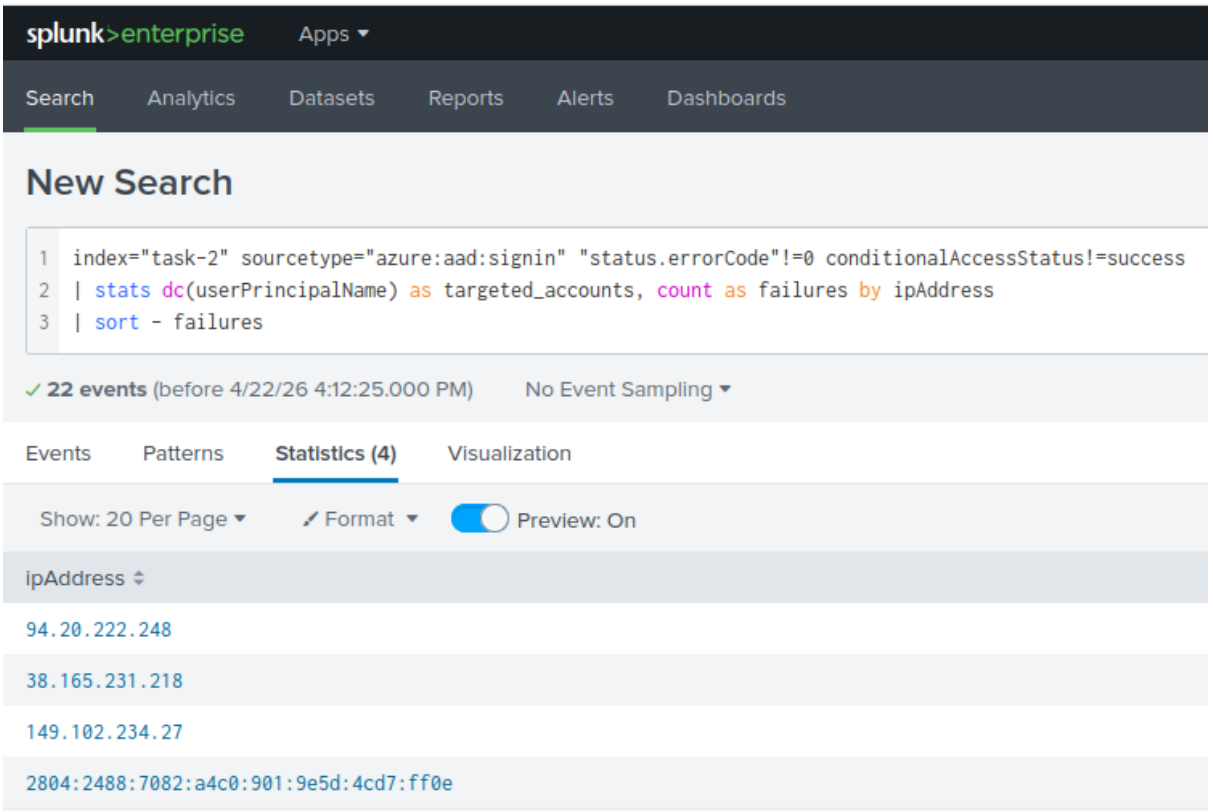
Para filtrar tentativas de login malsucedidas nos logs de login, irei usar a consulta abaixo. filtrando os status `conditionalAccessStatus` que não são iguais a `success`. Isso é necessário porque uma autenticação bem-sucedida pode apresentar códigos de erro em algumas etapas do processo de login.

```
index="task-2" sourcetype="azure:aad:signin" "status.errorCode"!=0
conditionalAccessStatus!=success
| table _time, userPrincipalName, appDisplayName, ipAddress, location.countryOrRegion,
status.errorCode, status.failureReason
| sort - _time
```



Esta consulta lista apenas as tentativas de ataque com falha contra identidades do Entra ID; no entanto, podemos aproveitar os recursos de consulta do Splunk (ou de qualquer outro SIEM) para identificar padrões de força bruta ou de pulverização de senhas com mais precisão. Por exemplo, a consulta abaixo pode revelar qual endereço IP teve o maior número de tentativas de ataque com falha e quantas contas foram alvo:

```
index="task-2" sourcetype="azure:aad:signin" "status.errorCode"!=0
conditionalAccessStatus!=success
| stats dc(userPrincipalName) as targeted_accounts, count as failures by ipAddress
| sort - failures
```



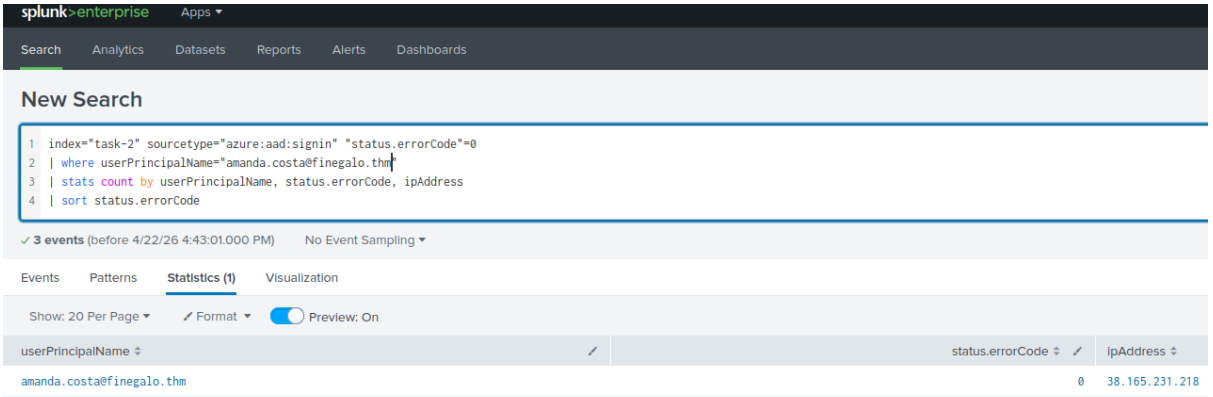
Após identificar um endereço IP que executa essas técnicas ou uma conta relevante que está sendo alvo, irei filtrar especificamente esses artefatos para investigar o comportamento suspeito.

Um bom ponto de partida é verificar se alguma autenticação foi bem-sucedida usando as consultas abaixo colocando o usuário e endereço IP que encontrei:

Usuário (Posso testar clicando no ip suspeito e View events:

index="task-2" sourcetype="azure:aad:signin" "status.errorCode"=0
| where userPrincipalName="rafael.maciel@finegalo.thm"
| stats count by userPrincipalName, status.errorCode, ipAddress
| sort status.errorCode

Esse primeiro não registrou nenhum registro porém o segundo que testei me informou esse login bm sucedido:



Ip Suspeito:

index="task-2" sourcetype="azure:aad:signin" "status.errorCode"=0
| where ipAddress="38.165.231.218 "
| stats count by userPrincipalName, status.errorCode
| sort status.errorCode

Resultado das descobertas:

Com o filtro `index="task-2" sourcetype="azure:aad:signin"
Vi todos os logs de login.

Endereço IP está realizando um ataque de pulverização de senhas
94.20.222.248 mostra 14 tentativas

failures
14

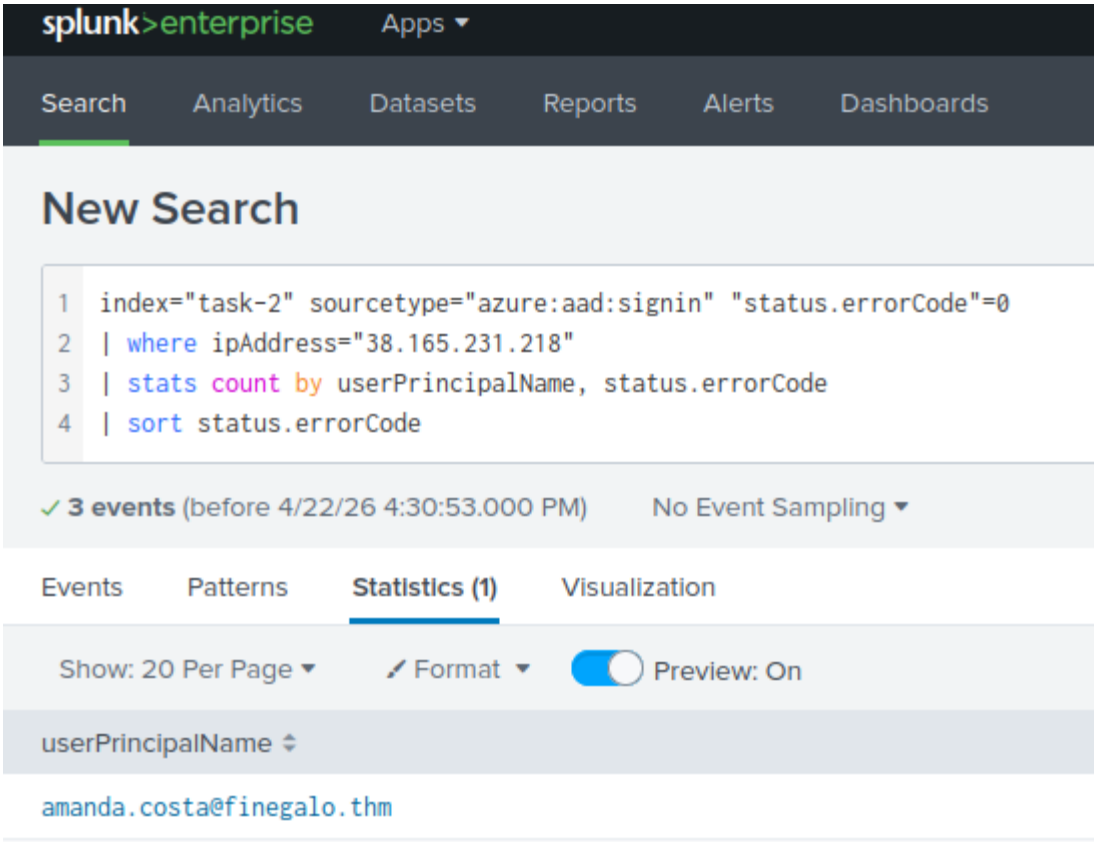
Endereço IP está realizando um ataque de força bruta com limitação de taxa
38.165.231.218 mostra 4 tentativas

4

Endereço de e-mail do usuário que foi comprometido
amanda.costa@finegalo.thm

Cheguei a essa conclusão ao usar essa pesquisar e comprovar que esse IP conseguiu logar:

```
index="task-2" sourcetype="azure:aad:signin" "status.errorCode"=0
| where ipAddress="38.165.231.218 "
| stats count by userPrincipalName, status.errorCode
| sort status.errorCode
```



Autor: Paulo Cesar
Formado em Segurança da informação
Linkedin: linkedin.com/in/paulo-cesar-security